PRADITA University

IT40813 · IT Governance, Risk & Compliance

Audit TI dan Asurans

Pertemuan 12

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Konsep Asurans
3. Three Lines Model
4. Standar Profesi
5. Perencanaan Berbasis Risiko
6. Pengujian Kontrol
7. Bukti dan Sampel
8. Temuan dan Tindak Lanjut
9. Asurans dari Luar
10. Aktivitas dan Penutup

PRADITA University

Unit TI melapor 108 dari 108. Mengapa audit tetap menemukan masalah?

Tujuan Pembelajaran

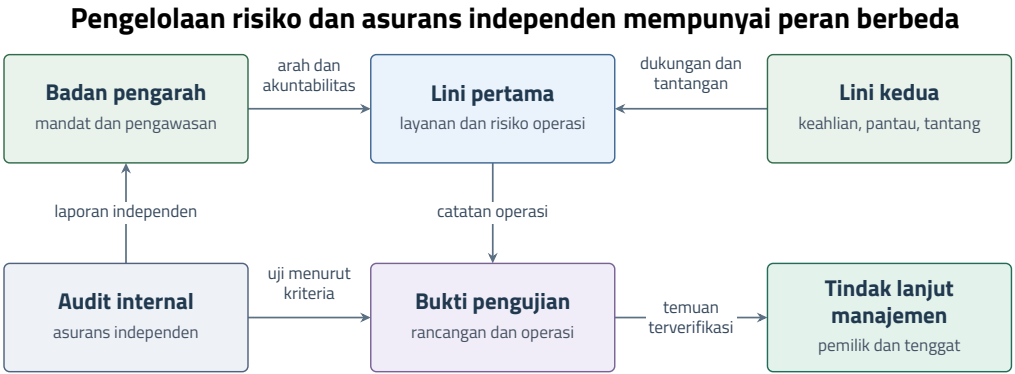
- Menjelaskan pembagian peran dalam Three Lines Model dan posisi audit internal yang independen.
- Menyusun rencana asurans berbasis risiko untuk program transformasi digital.
- Menguji rancangan dan efektivitas satu kontrol dengan bukti yang memadai.

Masalah: Dua Laporan, Dua Penyebut

- Misalkan unit TI melapor: 108 dari 108 akun sudah ditinjau.
- Audit internal memeriksa 30 dari 120 akun: 6 akun masih aktif setelah penugasan berakhir.
- Keduanya dapat benar. Daftar unit TI hanya memuat 108 akun, sehingga 12 akun luput.
- Dengan penyebut yang benar, cakupannya 90 persen, bukan 100 persen.
- Hasil kerja: rencana asurans dua tahun dan contoh pengujian satu kontrol untuk C4.

Diagram Konsep Bab 12

PRADITA University



Peran bukan jumlah departemen. Penutupan temuan memerlukan pengujian perbaikan; sampel membatasi kesimpulan audit.

Asurans: Keyakinan yang Punya Batas

PRADITA University

Pertanyaan	Laporan unit TI	Pengujian audit internal
Kriteria	Akun pada daftar sudah ditinjau	Dicabut paling lambat 1 hari kerja setelah penugasan berakhir
Populasi	108 akun pada daftar peninjau	120 akun pada daftar penugasan
Periode	Satu bulan terakhir, tanpa tanggal	Tanggal acuan 31 Maret 2026
Metode	Pernyataan pelaksana	Pencocokan dokumen dan 30 akun sampel
Pengecualian	Tidak disebut	Sampel satu lokasi; 4 rumah sakit lain belum punya bukti

Analogi pemeriksaan kendaraan: uji rem pada satu tanggal memberi bukti kondisi itu, bukan jaminan tidak akan pernah terjadi kecelakaan.

Asurans dan Konsultasi

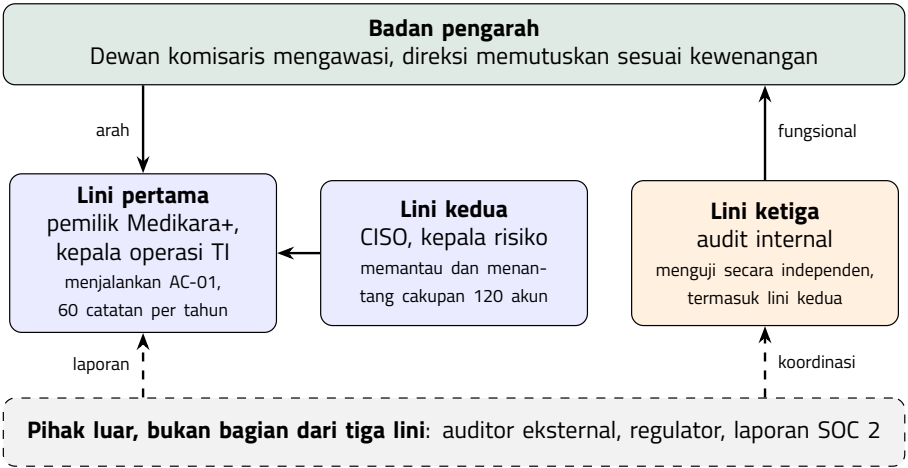
Aspek	Asurans	Konsultasi
Tujuan	Menilai terhadap kriteria	Membantu perbaikan
Kriteria	Wajib ditetapkan	Dapat tidak diperlukan, sesuai kesepakatan
Keluaran	Kesimpulan dan temuan	Saran dan pilihan
Tanggung jawab kontrol	Tetap pada manajemen	Tetap pada manajemen
Pengaman	Penilai tidak menjalankan proses yang dinilai	Peran jelas; keputusan pada manajemen; badan pengarah diberi tahu

Analogi guru les dan penguji: satu orang boleh memegang keduanya pada waktu berbeda, tetapi tidak menilai jawaban yang ia diktekan sendiri.

Dua Contoh Pemisahan

- Misalkan audit internal memberi saran 40 jam untuk KB-09 pada Tahun 1.
- Pemilik KB-09 tetap direktur pelayanan. Audit AI pada Tahun 2 dipimpin auditor lain.
- IIA: masa paling sedikit 12 bulan biasanya memadai antara tanggung jawab atas proses dan pemberian asurans.
- Misalkan petugas operasi TI menjalankan AC-01 sampai 31 Maret 2026, lalu pindah ke audit.
- Dengan acuan itu, ia sebaiknya tidak menguji AC-01 sebelum 1 April 2027.

Three Lines Model pada AC-01



Kekuatan dan Batas Tiap Peran

Peran	Contoh pemilik	Tanggung jawab	Batas
Badan pengarah	Dewan komisaris dan direksi sesuai kewenangan	Menetapkan arah, mengawasi	Bergantung pada informasi andal
Lini pertama	Pemilik Medikara+, kepala operasi TI, pemilik SIMRS	Menjalankan AC-01	Dapat meremehkan kelemahan kontrolnya
Lini kedua	CISO, kepala risiko, petugas pelindungan data	Memantau dan menantang	Kadang terganggu karena melapor lewat manajemen
Lini ketiga	Audit internal	Menguji secara independen	Berkala dan berbasis risiko

Peran, bukan jumlah departemen. Pengalihan pekerjaan ke vendor tidak mengubah akuntabilitas.

Independensi: Lima Unsur

Unsur	Bukti yang diperiksa	Tanda masalah
Jalur pelaporan dan wewenang	Piagam audit; laporan ke komite audit	Laporan harus melewati kepala TI
Otonomi ruang lingkup	Rencana disetujui dewan komisaris	Area AC-01 dicoret pihak yang diperiksa
Akses tanpa batas	Hak meminta daftar penugasan langsung	Daftar hanya datang dari operasi TI
Kendali sumber daya	Jam dan keahlian pada rencana	Jam dipotong tanpa dilaporkan
Perlindungan dari tekanan	Catatan perubahan laporan audit	Temuan diubah atas permintaan pemilik proses

Unit risiko melapor kepada direktur TI? Jabatan atasan saja belum membuktikan pelanggaran. Periksa mandat, akses, dan pengamannya.

Global Internal Audit Standards

Standar	Ketentuan ringkas	Bukti contoh
7.1	Independensi dikonfirmasi paling sedikit setahun sekali	Pernyataan tahunan
8.4	Penilaian mutu eksternal paling sedikit sekali dalam lima tahun	Rencana penilaian
9.4	Rencana audit berdasar penilaian risiko terdokumentasi, paling sedikit setahun sekali	Semesta audit
9.5	Koordinasi; dasar kepercayaan didokumentasikan	Peta asurans
14.1	Informasi relevan, andal, dan cukup	Kertas kerja 30 akun
15.2	Pelaksanaan rekomendasi dikonfirmasi dan dilacak	Status penutupan TA-01

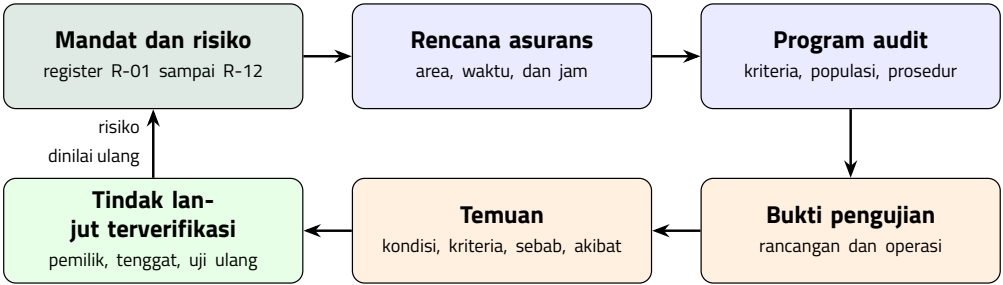
Berlaku sejak 9 Januari 2025: 5 domain, 15 prinsip, 52 standar. Ringkasan ini bukan terjemahan resmi.

ITAF dan Acuan Terbuka

PRADITA University

- ITAF edisi kelima adalah kerangka ISACA untuk audit dan asurans TI. Naskahnya berbayar.
- FISCAM revisi 2026 terbuka dan menjelaskan cara menguji kontrol sistem informasi.
- Government Auditing Standards 2024 terbuka dan menjelaskan unsur temuan.
- Keduanya ditulis untuk audit pemerintah Amerika Serikat, sehingga menjadi contoh metode.
- Analogi klinik kecil: ukuran mengubah cara dokumentasi, bukan kebutuhan akan catatan.

Siklus Asurans



Analogi pemeriksaan rumah: retakan struktur dan lampu hias mati tidak diperiksa dengan prioritas sama.

Semesta Audit dan Skor Prioritas (Misalkan)

PRADITA University

Area	Risiko	Skor	Ubah	Wajib	Lain	Prioritas	Jam
Akses vendor AC-01	R-01	12	3	5	1	19	600
AI klinis AI-01, AI-02	R-11	12	5	3	1	19	480
Pemulihan DSS04	R-05	10	5	2	1	16	480
Jejak aktivitas KB-06	R-02	12	3	3	2	16	240
Privasi dan retensi	R-09	9	3	5	2	15	200
Insiden dan pemberitahuan	R-12	8	3	5	2	14	240
Vendor inti dan cloud	R-08	8	5	3	3	13	320
Integrasi BPJS Kesehatan	R-03	9	3	2	1	13	200
Laporan spreadsheet	R-04	12	1	1	4	10	240
Rilis Medikara+	R-07	9	2	1	2	10	240
Jumlah							**3.240**

Prioritas = skor risiko + perubahan + kewajiban − asurans lain. Rumus pembelajaran, bukan ketentuan standar.

Kapasitas Membatasi Pilihan

PRADITA University

- 1 auditor TI 1.200 jam dan 1 auditor umum 600 jam: 1.800 jam per tahun, 3.600 jam dua tahun.
- Cadangan 20 persen mengambil 720 jam, sehingga jam terencana 2.880.
- Kebutuhan 3.240 jam. Dua area berprioritas terendah, 480 jam, ditunda. Sisa 120 jam.
- Celah cakupan dilaporkan kepada dewan komisaris. R-04 tetap berharapan kerugian Rp30 juta.
- Skor tidak mekanis: pemulihan harus sebelum migrasi, dan cedera berat memakai cadangan.

Rencana Asurans Dua Tahun (Misalkan)

Waktu	Area	Jam	Keputusan yang didukung
Tahun 1 awal	Akses vendor AC-01	600	Kesiapan perluasan mitra
Tahun 1 akhir	Pemulihan DS04	480	Kesiapan kelangsungan
Tahun 1 akhir	Insiden dan pemberitahuan	240	Kesiapan pemberitahuan
Sepanjang Tahun 1	Saran KB-09, laporan pihak luar	120	Rancangan kebijakan AI
Tahun 2	AI klinis AI-01, AI-02	480	Batas perluasan AI
Tahun 2	Jejak aktivitas KB-06	240	Keandalan penelusuran
Tahun 2	Privasi dan retensi	200	Batas pemakaian data
Tahun 2	Vendor inti dan cloud	320	Perpanjangan kontrak
Tahun 2	Integrasi BPJS Kesehatan	200	Kelangsungan pendaftaran

Tiap tahun 1.440 jam. Bila kapasitas dipangkas menjadi 1.200 jam, audit pemulihan tidak muat, dan pemangkasan itu dilaporkan ke komite audit.

Peta Asurans (Misalkan)

Area	Lini pertama	Lini kedua	Audit	Pihak luar
Akses vendor AC-01	60 catatan per tahun	CISO memantau 120 akun	Tahun 1	SOC 2, sisi penyedia
Pemulihan DSS04	144 uji per tahun	Kepala risiko meninjau hasil	Tahun 1	Tidak ada
Insiden	Prosedur KB-07	Petugas pelindungan data, 2 latihan	Tahun 1	Tidak ada
Jejak aktivitas	Tinjauan catatan aktivitas	CISO, 247 dari 260 tinjauan	Tahun 2	Tidak ada
AI klinis	Uji AI-01, AI-02	Kepala risiko, petugas pelindungan data	Tahun 2	Tidak ada
Vendor dan cloud	Pengelola vendor	Kepala risiko, register pemasok	Tahun 2	SOC 2 Type 2, sertifikat
Laporan spreadsheet	Rekonsiliasi manual	Kepala risiko	Ditunda	Audit keuangan saja

Bab 1: 276 permintaan menjadi 92 menghemat 368 jam, atau Rp22,08 juta per tahun. Audit internal dapat memilih tidak mengandalkan pekerjaan yang mutunya kurang.

Uji Rancangan dan Uji Efektivitas

	Operasi berjalan	Operasi tidak berjalan
Rancangan memadai	**Rancangan memadai, operasi berjalan** Kesimpulan efektif untuk lingkup itu. Sasaran: 120 dari 120 akun, 60 dari 60 catatan	**Rancangan memadai, operasi tidak berjalan** Perbaiki pelaksanaan, bukan kebijakan. Contoh: 12 dari 60 catatan tersedia
Rancangan lemah	**Rancangan lemah, operasi berjalan** Kontrol rajin dijalankan, tetapi meleset. Contoh: 108 dari 108 ditinjau, 12 akun luput	**Rancangan lemah, operasi tidak berjalan** Risiko belum ditangani. Contoh: rumah sakit tanpa peninjauan dan tanpa daftar

Analogi pintu: rancangan kunci dapat memadai, tetapi bukti pintu dikunci setiap malam memerlukan catatan pelaksanaan.

Program Audit AC-01 (Misalkan)

Pertanyaan	Jenis uji	Bukti	Hasil contoh
Siapa boleh menyetujui dan menjalankan?	Rancangan	Prosedur KB-03, pemisahan tugas	Ada pemisahan tugas
Apakah daftar peninjau lengkap?	Rancangan	Daftar peninjau, daftar penugasan	108 dari 120 akun
Apakah peninjauan bulanan di 5 rumah sakit?	Operasi	Catatan per lokasi	12 dari 60 catatan
Apakah akun dicabut paling lambat 1 hari kerja?	Operasi	Sampel 30 akun, tiket	24 sesuai, 6 menyimpang
Apakah pengecualian ditutup?	Tindak lanjut	Tiket, verifikasi ulang	24 dicabut, lalu 9, 5, 2

Kriteria Ditetapkan Sebelum Data Dibuka

PRADITA University

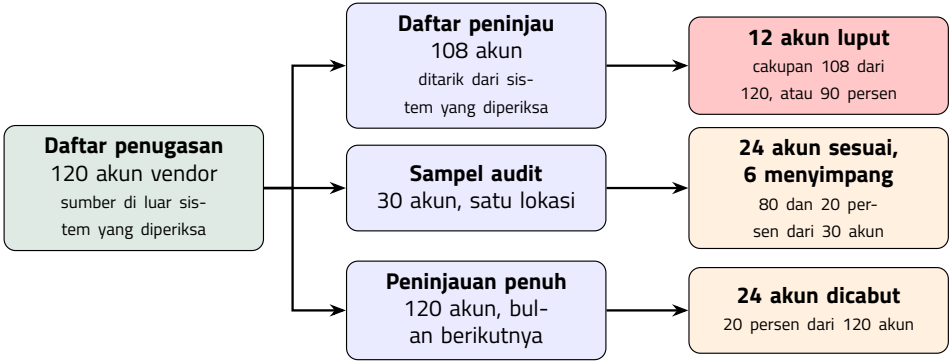
- Data latihan: 8 akun sintetis, 30 Oktober 2026. Satu tidak aktif dikeluarkan, jadi 7 aktif.
- USR002 tanpa pemilik, USR003 akun bersama dan terlambat, USR005 terlambat.
- Hasilnya 3 akun, 4 indikasi. Tinjauan tepat waktu 5 dari 7, atau 71,43 persen.
- Batas 90 hari hanya aturan skenario. Dengan 31 hari, hasilnya 3 dari 7, atau 42,86 persen.
- Indikasi memicu pemeriksaan lanjutan, bukan vonis penyalahgunaan.

Empat Jenis Uji pada AC-01

Jenis	Cara pada AC-01	Batasnya
Bertanya	Kepala operasi TI menjelaskan cara peninjauan	Tidak cukup bila berdiri sendiri
Mengamati	Auditor mendampingi peninjauan satu rumah sakit	Tidak membuktikan waktu lain
Memeriksa dokumen	Catatan bulanan dan tiket pencabutan	Dokumen prosedur hanya membuktikan rancangan
Mengulang	Auditor mencocokkan akun dengan daftar penugasan	Perlu akses dan pemeriksaan kelengkapan data

Bab 10: 29 dari 36 uji lulus, atau 80,6 persen. Pada 5 rumah sakit hanya 3 yang lulus, atau 60 persen. Angka gabungan menyamarkan lokasi.

Populasi Lebih Dahulu



Dua angka 24: 24 dari 30 akun sampel sesuai (80 persen), dan 24 dari 120 akun dicabut (20 persen). Yang pertama menghitung akun sesuai, yang kedua akun bermasalah.

Sampel Statistik dan Sampel Terarah

PRADITA University

- Sampel statistik dipilih acak dan dapat diproyeksikan. Sampel terarah tidak dimaksudkan begitu.
- Sampel 30 akun Bab 4 hanya mewakili satu lokasi, sehingga 20 persen tidak diproyeksikan.
- Analogi sayur: satu sendok dari permukaan panci hanya menjelaskan permukaannya.
- Misalkan audit ulang bertingkat: 40, 24, 20, 20, 16 akun menjadi sampel 10, 6, 5, 5, 4.
- Sampel dari daftar 108 tidak mungkin menyentuh 12 akun yang luput.

Apa yang Dapat Dikatakan Sampel Acak?

Hasil pada sampel 30	Perkiraan titik	Batas bawah	Batas atas
6 dari 30 menyimpang	24 akun	13 akun	40 akun
2 dari 30 menyimpang	8 akun	2 akun	21 akun
0 dari 30 menyimpang	0 akun	0 akun	9 akun

Akun bermasalah pada populasi	Peluang tertangkap sampel 30	Sampel minimal 95 persen
12 akun	97,40 persen	26 akun
2 akun	43,91 persen	93 akun
1 akun	25,00 persen	114 akun

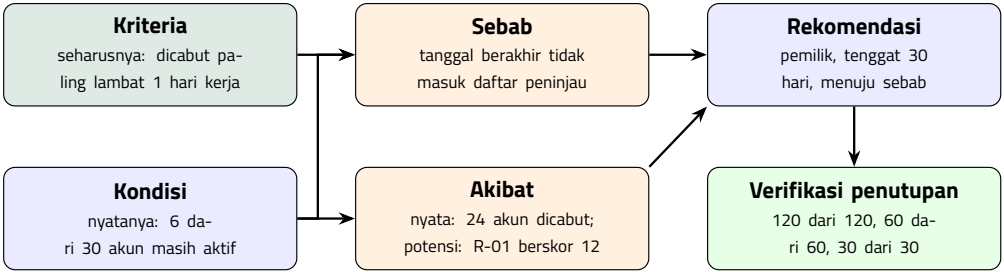
Populasi 120 akun, sebaran hipergeometrik, keyakinan 95 persen satu sisi.

Toleransi Nol Menuntut Uji Seluruh Populasi

PRADITA University

- Hasil 30 dari 30 masih menyisakan kemungkinan sampai 9 akun bermasalah.
- *Risk appetite* nol akun tanpa pemilik karena itu diuji pada 120 dari 120 akun.
- Manual 20 menit per akun: 40 jam atau Rp2,4 juta. Dengan skrip: 12 jam atau Rp720 ribu.
- Harapan kerugian R-01 Rp100 juta per tahun. Biaya bukan alasan untuk tidak menguji semua.
- Sampel tetap berguna untuk keaslian persetujuan. Catatan bulanan dibaca 60 dari 60.

Unsur Temuan



Analogi atap: “lantai basah” belum menjelaskan kriteria, asal air, akibat, dan perbaikan.

Kasus Medikara: Temuan TA-01 (Misalkan)

Unsur	Isi	Status
Kondisi	6 dari 30 akun masih aktif setelah penugasan berakhir; daftar 108 dari 120 akun; catatan 12 dari 60	Terbukti pada sampel satu lokasi
Kriteria	Dicabut paling lambat 1 hari kerja; nol akun tanpa pemilik; peninjauan bulanan pada 5 rumah sakit	Disetujui
Sebab	Tanggal berakhir tidak masuk daftar; daftar dari sistem yang diperiksa; belum ada peninjau lintas lokasi	Dua terkonfirmasi, satu dugaan
Akibat	Nyata: 24 akun dicabut. Potensi: R-01 berskor 12, peringkat Tinggi	Nyata dan potensi terpisah
Rekomendasi	Masukkan tanggal berakhir, populasi dari daftar penugasan, 5 rumah sakit	Menuju sebab
Pemilik, tenggat	Pemilik risiko pemilik Medikara+; tindakan kepala operasi TI; 30 hari	Disepakati
Verifikasi	120 dari 120 akun, 60 dari 60 catatan, 30 dari 30 sampel	Belum diuji

Selisih harapan kerugian Rp85 juta dan Rp25 juta adalah Rp60 juta, lebih besar dari biaya audit area ini, Rp36 juta. Temuan tidak menyatakan 6 akun itu membocorkan data.

Tindak Lanjut Sampai Terverifikasi

- Empat status: terbuka, selesai menurut manajemen, diuji ulang, dan ditutup.
- Prosedur KB-03 terbit: statusnya baru selesai menurut manajemen.
- Pencabutan turun dari 24 menjadi 9, 5, dan 2. Bila daftarnya masih 108, penyebutnya salah.
- Standar 15.2: tanyakan kemajuan, nilai lanjutan, dan perbarui status pada sistem pelacakan.
- Keterlambatan tanpa keputusan berarti risiko diterima tanpa disebut.

Membaca Laporan Audit Nyata

PRADITA University

- OCR Amerika Serikat mengaudit 166 penyedia layanan dan 41 mitra usaha, 2016 sampai 2017.
- Menurut ringkasan sekunder, 14 persen penyedia memenuhi tanggung jawab analisis risiko.
- Pada manajemen risiko, angkanya hanya 6 persen. Skala penilaiannya 1 sampai 5.
- Pelajaran pertama: angka bermakna bila populasi dan skalanya disebut.
- Pelajaran kedua: menganalisis berbeda dari mengelola. Angka ini tidak disalin ke Medikara.

Bentuk Asurans dari Luar

Bentuk	Yang dijawab	Yang belum dijawab
Audit laporan keuangan	Keandalan laporan keuangan	Apakah akun vendor sudah dicabut
Inspeksi regulator, akreditasi	Kepatuhan pada ketentuan tertentu	Efektivitas seluruh kontrol TI
Sertifikat ISO/IEC 27001	Sistem manajemen pada ruang lingkup itu	Di luar ruang lingkup
SOC 2 Type 1	Rancangan dan penerapan pada satu tanggal	Operasi sepanjang periode
SOC 2 Type 2	Operasi kontrol penyedia selama periode	Sisa waktu; kontrol pelengkap pengguna
ISAE 3402 Type 2	Kontrol terkait pelaporan keuangan	Kerahasiaan data pasien, bila di luar lingkup

Keputusan Mengandalkan Laporan

PRADITA University

- SOC 2 Type 2 mencakup 1 Januari sampai 30 Juni 2026, dibaca 1 November 2026: sekitar 4 bulan kosong.
- 3 dari 25 sampel pencabutan menyimpang, atau 12 persen. Uji pencabutan tidak dikurangi.
- Medikara menjalankan 9 dari 14 kontrol pelengkap. Lima sisanya diuji sendiri.
- Bila tidak dapat diandalkan, prioritas area vendor naik dari 13 menjadi 16.
- ISAE 3402 untuk penagihan tidak otomatis menjawab kerahasiaan hasil laboratorium.

Aktivitas: Rencana dan Uji Kontrol

PRADITA University

1. Petakan tiga lini dan badan pengarah. Isi peta asurans.
2. Susun semesta audit, hitung prioritas, dan cocokkan jam dengan kapasitas.
3. Pilih satu kontrol. Tetapkan kriteria, populasi, dan tanggal acuan sebelum membuka data.
4. Uji rancangan, lalu uji operasi dengan data sintetis.
5. Tulis satu temuan, tetapkan pemilik, tenggat, dan uji ulang.

Peran: anggota berlatar akuntansi atau audit memimpin; analis teknologi menyiapkan data; analis risiko menautkan register; pemilik konteks menilai kelayakan rekomendasi.

Luaran, Penilaian, dan Berkas

- Luaran C4: peta peran, peta asurans, rencana dua tahun, program uji, dan satu temuan.
- Bab 13 memakai hasil uji sebagai bahan indikator. Bab 14 memakai rencana pada peta jalan.
- Kriteria 25 persen; bukti dan hitungan 35 persen; temuan 25 persen; batas klaim 15 persen.
- Berkas: `sources/chapter12/README.md`.
- Opsional: audit berbantuan komputer pada *log* sintetis atau berizin tertulis.

Ringkasan

- Asurans memberi keyakinan dengan batas ruang lingkup, periode, populasi, dan metode.
- Three Lines Model membagi peran. Jalur pelaporan dinilai dari mandat dan pengamannya.
- Rencana audit mengikuti risiko dan kapasitas. Celah cakupan dilaporkan.
- Populasi ditetapkan sebelum sampel. Toleransi nol diuji pada seluruh populasi.
- Keyakinan lahir dari bukti yang dapat diulang. Penutupan temuan memerlukan bukti perbaikan.

Latihan

1. Unit manajemen risiko di sebuah rumah sakit melapor kepada direktur TI. Apa masalahnya menurut Three Lines Model, dan bagaimana memperbaikinya?
2. Jelaskan perbedaan uji rancangan dan uji efektivitas dengan contoh kontrol peninjauan hak akses.
3. Tulis satu temuan audit lengkap untuk kasus kebocoran data lewat vendor Medikara pada 2025.

Contoh terisi dan lembar isian ada pada bab.